

Appunti — Modulo D8: Privacy e Protezione dei Dati Personali

Corso: Diritto dell'Informatica T

Normative: Reg. UE 2016/679 (GDPR) + D.Lgs. 196/2003 (Codice Privacy)

PDF: 08_DirInfo_2026_Privacy_DEF.pdf (63 slide)

Obiettivo

Approfondimento della disciplina di protezione dei dati personali: applicazione del GDPR, definizioni fondamentali, soggetti coinvolti, principi e basi giuridiche del trattamento, obblighi del titolare, diritti dell'interessato, misure di sicurezza, violazioni, DPIA, DPO, trasferimenti extra UE e sanzioni.

§1 — Norme di Riferimento

- **Reg. UE 2016/679** → GDPR (*General Data Protection Regulation*) — in vigore dal 25 maggio 2016, applicabile dal 25 maggio 2018; lascia margini di autonomia agli Stati Membri.
- **D.Lgs. 196/2003** → Codice Privacy — aggiornato a settembre 2018 per adeguarlo al GDPR.

Nota: il GDPR non è l'unica fonte. Si applicano anche Codice Privacy aggiornato, altre normative pertinenti (es. Statuto dei lavoratori), Linee Guida del Comitato Europeo per la Protezione dei Dati, provvedimenti del Garante.

§2 — Cosa Tutela il GDPR

Il GDPR protegge i **diritti e le libertà fondamentali delle persone fisiche**, in particolare il **diritto alla protezione dei dati personali**, garantito a **chiunque**.

NON si applica a: - **persone giuridiche** (aziende, società, enti) - **dati anonimi**, se è effettivamente impossibile identificare la persona

Si applica **indipendentemente dal modo** in cui vengono trattati i dati — sia manualmente (es. piccolo giornale indipendente con nuovi iscritti in forma cartacea) che automaticamente (es. sito con newsletter online).

§3 — Ambito di Applicazione Materiale

Questa sezione non era presente negli appunti grezzi.

Il Regolamento **si applica** al trattamento di dati personali: - interamente o parzialmente **automatizzato**, e - **non automatizzato** di dati personali contenuti in un archivio o destinati a figurarvi.

Non si applica al trattamento effettuato: - da **persone fisiche** per attività **esclusivamente personali o domestiche** (es. rubrica telefonica privata, social media per uso personale senza attività commerciale); - dalle **autorità competenti** a fini di prevenzione, indagine, accertamento o perseguimento di reati, o salvaguardia della sicurezza pubblica.

§4 — Ambito di Applicazione Territoriale

Questa sezione non era presente negli appunti grezzi.

Il Regolamento si applica al trattamento di dati personali:

1. effettuato da **titolare o responsabile stabilito nell'UE**, indipendentemente dal luogo di trattamento;
2. effettuato da **titolare o responsabile non stabilito nell'UE**, se riguarda **dati di interessati che si trovano nell'UE**, per:
 - l'offerta di beni o la prestazione di servizi, **oppure**
 - il monitoraggio del loro comportamento all'interno dell'UE.

Sintesi: tutela i dati degli europei, raccolti da soggetti europei **e non**. Un titolare che non risiede in Europa, se tratta dati di cittadini europei, deve rispettare il GDPR.

§5 — Che cos'è un Dato Personale

«Qualsiasi informazione riguardante una persona fisica identificata o identificabile; si considera identificabile la persona fisica che può essere identificata, direttamente o indirettamente, con particolare riferimento a un identificativo come il nome, un numero di identificazione, dati relativi all'ubicazione, un identificativo online o a uno o più elementi caratteristici della sua identità fisica, fisiologica, genetica, psichica, economica, culturale o sociale.» (art. 4, par. 1, GDPR)

I dati personali si distinguono in: - **Comuni** — es. nome, cognome, indirizzo, e-mail, numero di telefono - **Sensibili** (categorie particolari, art. 9) — trattati con disciplina più restrittiva (v. §12)

§6 — Il Concetto di Trattamento

«Qualsiasi operazione o insieme di operazioni, compiute con o senza l'ausilio di processi automatizzati e applicate a dati personali o insiemi di dati personali», come: raccolta, registrazione, organizzazione, strutturazione, conservazione, adattamento o modifica, estrazione, consultazione, uso, comunicazione, diffusione, raffronto, interconnessione, limitazione, cancellazione o distruzione.

Attività specifiche di trattamento

Profilazione: qualsiasi forma di trattamento automatizzato per valutare aspetti personali di una persona fisica — in particolare per analizzare o prevedere il rendimento professionale, la salute, le preferenze, gli interessi, l'affidabilità, il comportamento, l'ubicazione o gli spostamenti.

Esempio: un'app di fitness che analizza i dati di movimento per prevedere problemi di salute futuri sta effettuando profilazione.

Pseudonimizzazione: trattamento dei dati in modo tale che non possano più essere attribuiti a un interessato specifico senza l'utilizzo di informazioni aggiuntive, **a condizione che** tali informazioni aggiuntive siano conservate separatamente e siano protette con misure tecniche/organizzative adeguate.

Differenza chiave: la **pseudonimizzazione** *riduce* il rischio di identificare le persone (il dato è ancora personale ma più difficile da ricondurre); l'**anonimizzazione** *elimina* il rischio (il dato non è più personale). Un dato pseudonimizzato rimane sotto la disciplina GDPR; un dato anonimo no.

§7 — I Soggetti Coinvolti nel Trattamento

Titolare del trattamento

La persona fisica o giuridica, l'autorità pubblica, il servizio o altro organismo che, **singolarmente o insieme ad altri**, determina **finalità e mezzi** del trattamento dei dati personali.

Tratta dati per **proprio conto** — es. una società che tratta i dati dei propri clienti e dipendenti.

Responsabile del trattamento

La persona fisica o giuridica, l'autorità pubblica, il servizio o altro organismo che **tratta dati personali per conto del titolare**.

Non decide autonomamente finalità e mezzi — **segue le direttive del titolare**.

Esempi: consulente del lavoro che elabora buste paga usando i dati dei dipendenti del cliente; call center che contatta i clienti del committente; fornitore cloud che tratta dati per conto dei propri clienti.

Il responsabile: - deve fornire **garanzie sufficienti** per misure tecniche/organizzative adeguate; - può nominare a sua volta un **sub-responsabile** solo con **autorizzazione scritta** del titolare; - deve trattare i dati **solo su istruzione documentata** del titolare.

Come è nominato: occorre un **contratto** (o altro atto giuridico) che stipuli: materia, durata, natura e finalità del trattamento, tipo di dati, categorie di interessati, obblighi e diritti del titolare.

Attenzione: non confondere “Responsabile del trattamento” (*data processor*) con “Responsabile della protezione dei dati” (*Data Protection Officer* — DPO).

Interessato

Persona **fisica** a cui si riferiscono i dati personali. Es. utente, cliente, paziente.

Soggetto Autorizzato/Designato

Persona **fisica**, collaboratore o dipendente del Titolare o del Responsabile, che opera sotto la loro autorità diretta. **Nessuna autonomia decisionale** sul trattamento. Deve trattare i dati conformemente al GDPR e alle istruzioni ricevute. (v. Codice Privacy, art. 2-*quaterdecies*)

§8 — Obblighi del Titolare del Trattamento (art. 25 GDPR)

Privacy by Design (protezione dei dati fin dalla progettazione)

Il titolare deve mettere in atto **misure tecniche e organizzative adeguate** (es. pseudonimizzazione) per: - attuare i principi di protezione dei dati (es. minimizzazione); - integrare le garanzie necessarie per soddisfare i requisiti del Regolamento e tutelare i diritti degli interessati.

Questo obbligo scatta **due volte**: 1. al momento di **determinare i mezzi** del trattamento (fase progettuale); 2. **all'atto del trattamento stesso** (fase operativa).

Esempio pratico di *privacy by design*: un'app di messaggistica che, fin dall'architettura, non conserva i metadati delle conversazioni sui server — la protezione è incorporata nella struttura tecnica, non aggiunta in seguito.

Privacy by Default (protezione dei dati per impostazione predefinita)

Il titolare deve garantire che, **senza necessità di intervento dell'utente**, vengano trattati **solo i dati personali necessari** per ogni specifica finalità. Questo vale per: - la **quantità** dei dati raccolti; - la **portata** del trattamento; - il **periodo** di conservazione; - l'**accessibilità** dei dati.

Cosa significa “senza intervento della persona fisica”: per impostazione predefinita, i dati personali **non devono essere accessibili a un numero indefinito di persone fisiche** — cioè l'accesso deve essere ristretto, non aperto a chiunque per default. È l'utente che, se lo desidera, amplia la condivisione; non è il sistema a condividerli con tutti finché l'utente non dice “basta”.

Esempio pratico di *privacy by default*: un social network che, per impostazione predefinita, imposta il profilo come “visibile solo agli amici” — l'utente deve attivamente scegliere di renderlo pubblico. Al contrario, impostare il profilo “pubblico a tutti” come default violerebbe questo principio.

Cosa può chiedermi l'esame sull'art. 25: la professoressa ha indicato questo articolo come da studiare. Le domande tipiche riguardano: (1) differenza concettuale tra *by design* e *by default*; (2) in quale fase del ciclo di vita si applica ciascuno; (3) esempi concreti; (4) qual è la sanzione in caso di violazione (fascia 10M€ / 2% fatturato).

§9 — Principi Applicabili al Trattamento (art. 5 GDPR)

I dati personali devono essere:

1. **Liceità, correttezza e trasparenza** — trattati in modo lecito, corretto e trasparente nei confronti dell'interessato.
2. **Limitazione della finalità** — raccolti per finalità determinate, esplicite e legittime, e successivamente trattati in modo non incompatibile con tali finalità. (*Eccezione: ulteriore trattamento a fini di archiviazione nel pubblico interesse, ricerca scientifica/storica o fini statistici non è considerato incompatibile.*)
3. **Minimizzazione dei dati** — adeguati, pertinenti e limitati a quanto necessario rispetto alle finalità per le quali sono trattati.

4. **Esattezza** — esatti e, se necessario, aggiornati; devono essere adottate tutte le misure ragionevoli per cancellare o rettificare tempestivamente i dati inesatti.
 5. **Limitazione della conservazione** — conservati in una forma che consenta l'identificazione degli interessati per un arco di tempo non superiore al conseguimento delle finalità per le quali sono trattati. (*Eccezione: periodi più lunghi sono possibili a fini di archiviazione nel pubblico interesse, ricerca scientifica/storica o fini statistici.*)
 6. **Integrità e riservatezza** — trattati in maniera da garantire un'adeguata sicurezza, compresa la protezione da trattamenti non autorizzati o illeciti e dalla perdita, distruzione o danno accidentali.
 7. **Responsabilizzazione** (*accountability*) — il titolare del trattamento è competente per il rispetto di tutti questi principi e deve essere in grado di **comprovarlo** e **dimostrarlo**.
-

§10 — Liceità del Trattamento — Basi Giuridiche (art. 6 GDPR)

Il trattamento è **lecito solo se** ricorre **almeno una** delle seguenti condizioni:

1. **Consenso** — l'interessato ha espresso il consenso per una o più specifiche finalità. > Es. l'utente spunta la casella "acconsento all'invio di newsletter promozionali".
 2. **Esecuzione di contratto** — il trattamento è necessario all'esecuzione di un contratto di cui l'interessato è parte, o a misure precontrattuali adottate su sua richiesta. > Es. un negozio online tratta l'indirizzo di spedizione per consegnare il prodotto acquistato — non serve consenso separato.
 3. **Obbligo legale** — il trattamento è necessario per adempiere un obbligo legale al quale è soggetto il titolare. > Es. un datore di lavoro deve trasmettere dati dei dipendenti all'INPS ai fini previdenziali — è un obbligo di legge, non serve consenso dei dipendenti.
 4. **Interessi vitali** — il trattamento è necessario per la salvaguardia degli interessi vitali dell'interessato o di un'altra persona fisica. > Es. un medico del pronto soccorso che tratta i dati sanitari di un paziente privo di sensi e senza familiari presenti — non è possibile raccogliere il consenso, ma il trattamento è necessario per salvare la vita.
 5. **Interesse pubblico o pubblici poteri** — il trattamento è necessario per l'esecuzione di un compito di interesse pubblico o connesso all'esercizio di pubblici poteri di cui è investito il titolare. > Es. un comune che tratta i dati anagrafici dei residenti per erogare servizi pubblici; una scuola pubblica che gestisce i dati degli studenti per finalità didattiche.
 6. **Legittimo interesse** — il trattamento è necessario per il perseguimento del legittimo interesse del titolare o di terzi, **a condizione che** non prevalgano gli interessi o i diritti e le libertà fondamentali dell'interessato (in particolare se l'interessato è un minore). **Non** si applica al trattamento effettuato dalle autorità pubbliche nell'esecuzione dei loro compiti. > Es. un'azienda che monitora gli accessi alla propria rete interna per motivi di sicurezza informatica — ha un interesse legittimo a proteggere i propri sistemi. Tuttavia, un monitoraggio sistematico e invasivo di ogni attività dei dipendenti potrebbe non superare il bilanciamento con i loro diritti fondamentali.
-

§11 — Condizioni per il Consenso

Se il trattamento si basa sul **consenso**, il titolare deve poterlo **dimostrare** (onere della prova sul titolare).

Se il consenso è prestato nel contesto di una dichiarazione scritta che riguarda anche altre questioni, la richiesta deve essere presentata in modo **chiaramente distinguibile** dalle altre materie.

Cosa significa “chiaramente distinguibile”: il consenso al trattamento dei dati non può essere “nascosto” nel mezzo di un lungo testo contrattuale o nei termini generali di servizio. Deve essere fisicamente/visivamente separato — es. una sezione dedicata, una checkbox specifica, non una clausola immersa nel testo standard del contratto. Se il consenso è “sepolto” nelle condizioni generali, quella parte non è vincolante.

La richiesta deve essere in forma **comprensibile e facilmente accessibile**, usando **linguaggio semplice e chiaro**. Nessuna parte di una dichiarazione che costituisca una violazione del Regolamento è vincolante.

L'interessato **ha diritto di revocare il proprio consenso in qualsiasi momento**, con la stessa facilità con cui è stato accordato. La revoca **non pregiudica** la liceità del trattamento basata sul consenso prima della revoca.

La postilla sul consenso condizionato al servizio (art. 7, par. 4): nel valutare se il consenso sia stato liberamente prestato, si tiene nella massima considerazione l'eventualità che l'**esecuzione di un contratto** (o la **prestazione di un servizio**) sia **condizionata** alla prestazione del consenso al trattamento di dati **non necessari** per quell'esecuzione.

Tradotto: se per usare un servizio sei **costretto** a dare il consenso a trattamenti che non sono strettamente necessari al servizio stesso, quel consenso non è considerato “liberamente prestato” — e quindi non è una base giuridica valida.

Esempio: un'app meteo che ti dice “per usare l'app devi accettare che usiamo i tuoi dati per marketing di terze parti” — il trattamento marketing non è necessario per darti le previsioni del tempo. Il consenso così ottenuto è viziato.

Consenso dei minori

Per l'offerta diretta di servizi della società dell'informazione ai minori, il trattamento è lecito ove il minore abbia almeno **16 anni**. Per età inferiore, il consenso deve essere prestato o autorizzato dal **titolare della responsabilità genitoriale**.

Gli Stati Membri possono stabilire un'età inferiore, **ma non sotto i 13 anni**. In **Italia** è fissata a **14 anni** (art. 2-*quiquies* Codice Privacy).

§12 — Trattamento di Categorie Particolari di Dati Personali — Dati Sensibili (art. 9 GDPR)

È **vietato** trattare dati personali che rivelino: **origine razziale o etnica**, **opinioni politiche**, **convinzioni religiose o filosofiche**, **appartenenza sindacale**; nonché **dati genetici**, **dati bio-**

metrici intesi a identificare in modo univoco una persona fisica, dati relativi alla **salute**, alla **vita sessuale** o all'**orientamento sessuale**.

Precisazione: l'espressione "intesi a identificare in modo univoco" si riferisce **solo ai dati biometrici** (es. impronta digitale, riconoscimento facciale). Non a tutti i dati sensibili. Gli altri (es. opinioni politiche, salute) sono vietati per la loro natura intrinsecamente delicata, non perché identifichino univocamente.

Eccezioni — quando il divieto non vale:

Lettera	Condizione	Esempio concreto
A	Consenso esplicito dell'interessato per una o più finalità specifiche	Paziente che autorizza espressamente la condivisione della cartella clinica con un secondo specialista
B	Necessario per obblighi e diritti in materia di diritto del lavoro e sicurezza sociale, nella misura autorizzata da diritto UE/nazionale o contratto collettivo	Azienda che tratta i dati sanitari per calcolare le assenze per malattia secondo il CCNL
C	Necessario per tutelare un interesse vitale quando l'interessato è incapace di prestare il consenso	Medico che accede alla storia clinica di un paziente in coma
D	Trattamento da fondazione/associazione senza scopo di lucro con finalità politiche, filosofiche, religiose o sindacali — limitato ai propri membri/ex membri e senza comunicazione esterna senza consenso	Partito politico che tratta i dati di opinione politica dei propri iscritti
E	Dati manifestamente resi pubblici dall'interessato	Politico che ha dichiarato pubblicamente la propria appartenenza religiosa in un'intervista
F	Necessario per accertare, esercitare o difendere un diritto in sede giudiziaria	Avvocato che usa dati sanitari del cliente per dimostrare un danno alla salute in un processo risarcitorio
G	Necessario per motivi di interesse pubblico rilevante sulla base del diritto UE o nazionale	Autorità sanitaria che raccoglie dati sulla diffusione di una malattia infettiva
H	Necessario per medicina preventiva, diagnosi, assistenza sanitaria o sociale	Medico di base che tratta la cartella clinica del paziente

Lettera	Condizione	Esempio concreto
I	Necessario per motivi di interesse pubblico nel settore della sanità pubblica	Campagne di vaccinazione nazionale
J	Necessario a fini di archiviazione nel pubblico interesse, ricerca scientifica/storica, fini statistici	Ricercatore universitario che analizza dati anonimizzati sulla salute della popolazione

§13 — L’Importanza dell’Informativa (artt. 12, 13, 14 GDPR)

PRIMA di raccogliere i dati deve essere fornita un’**informativa** (*nota: nel testo grezzo “informatica” è un refuso — il termine corretto è “informativa”*) con un contenuto minimo:

- identità e dati di contatto del **titolare del trattamento**;
- dati di contatto del **DPO** (se nominato);
- **finalità** del trattamento e **base giuridica** del trattamento;
- eventuali **destinatari** o categorie di destinatari dei dati personali;
- **intenzione** del titolare di trasferire dati personali a un **paese terzo** o a un’organizzazione internazionale;

(**risposta alla domanda “anche se europeo?”**: la dicitura “paese terzo” nel GDPR significa un paese al di fuori dell’UE/SEE. Se il trasferimento avviene verso un altro Stato Membro dell’UE, non è un trasferimento a “paese terzo” e non richiede menzione nell’informativa per questo motivo. Il trasferimento verso paesi non-UE (es. USA, India) deve invece essere indicato.)

- **periodo di conservazione** dei dati (o i criteri per determinarlo);
- **diritti** dell’interessato (accesso, rettifica, cancellazione, limitazione, opposizione, portabilità);
- diritto di **revocare il consenso** in qualsiasi momento;
- diritto di proporre **reclamo** a un’autorità di controllo;
- se la comunicazione dei dati è un **obbligo legale o contrattuale** o requisito per concludere un contratto, e le conseguenze della mancata comunicazione;
- esistenza di un **processo decisionale automatizzato**, compresa la **profilazione** (art. 22).

§14 — Diritti dell’Interessato (artt. 15–22 GDPR)

Perché artt. 15-22 sono segnati da “leggere attentamente”: questi articoli definiscono i diritti azionabili dall’interessato, che sono domande tipiche d’esame sia in forma teorica (“elenca i diritti”) sia in forma applicativa (“Mario vuole cancellare i suoi dati — quale diritto può esercitare?”). Sono anche il cuore pratico del GDPR: saper rispondere a una richiesta di un interessato è un obbligo del titolare.

Diritto	Articolo	In pratica cosa consente
Accesso	Art. 15	Ottenere la conferma che siano o meno in corso trattamenti che lo riguardano; ottenere copia dei dati trattati; conoscere finalità, categorie di dati, destinatari, periodo di conservazione
Rettifica	Art. 16	Chiedere la correzione di dati inesatti che lo riguardano
Integrazione	Art. 16	Chiedere l'integrazione di dati incompleti
Cancellazione / “diritto all’oblio”	Art. 17	Chiedere la cancellazione dei propri dati (es. quando non sono più necessari rispetto alle finalità, o quando si revoca il consenso e non vi è altra base giuridica)
Limitazione del trattamento	Art. 18	Chiedere che il trattamento dei propri dati sia sospeso temporaneamente (es. mentre si contesta l’esattezza dei dati)
Portabilità dei dati	Art. 20	Ricevere i propri dati in formato strutturato, di uso comune e leggibile da dispositivo automatico, per trasferirli a un altro titolare
Opposizione	Art. 21	Opporsi in qualsiasi momento al trattamento dei propri dati, in particolare per finalità di marketing diretto o profilazione

§15 — Registri delle Attività di Trattamento (art. 30 GDPR)

Chi è obbligato a tenerli?

- Imprese con **più di 250 dipendenti** — sempre.
- Imprese con **meno di 250 dipendenti** — se:
 - il trattamento può presentare un **rischio** per i diritti e le libertà dell’interessato (es. sorveglianza dei lavoratori);
 - il trattamento **non è occasionale** (es. trattamento continuativo di dati di clienti);
 - include il trattamento di **categorie particolari di dati** (es. dati sanitari dei dipendenti).

Esempi per ciascuna casistica: - *Rischio*: una PMI che usa sistemi di videosorveglianza avanzata o che monitora sistematicamente le email dei dipendenti. - *Non occasionale*: una piccola palestra che gestisce abbonamenti — tratta continuativamente dati dei soci. - *Categorie particolari*: uno studio medico con meno di 250 dipendenti tratta dati sanitari — obbligo automatico.

I registri vanno tenuti **in forma scritta**, anche elettronica, e messi a disposizione del Garante in caso di controllo.

Registro del Titolare — contenuto:

- nome e dati di contatto del titolare e del **DPO** (se nominato)
- (risposta alla domanda “DPO (?)”: nei registri vanno inclusi i dati di contatto del DPO perché il Garante, in caso di controllo, deve poterlo contattare direttamente. È anche

un obbligo di trasparenza verso gli interessati.)

- finalità del trattamento;
- categorie di interessati e di dati personali;
- categorie dei destinatari;
- trasferimenti verso paesi terzi;
- termini ultimi per la cancellazione;
- **descrizione generale** delle misure di sicurezza.

Registro del Responsabile — contenuto:

- nome e dati di contatto del responsabile e del titolare per cui agisce, e del DPO;
- categorie dei trattamenti effettuati per conto di ogni titolare;
- trasferimenti verso paesi terzi;
- **descrizione generale** delle misure di sicurezza tecniche e organizzative.

(risposta alla domanda “più approfondite di quelle del registro del titolare?”) Formalmente entrambi usano “descrizione generale”. In pratica, il registro del Responsabile descrive le misure operative che il Responsabile stesso adotta (es. cifratura specifica, procedure di accesso), mentre quello del Titolare ha una visione d’insieme. Non c’è una differenza di livello di dettaglio imposta dalla norma: entrambi devono essere sufficienti a dimostrare la compliance.

§16 — Misure di Sicurezza (art. 32 GDPR) — Studio: ART. 24

Il titolare deve attuare **misure tecniche e organizzative adeguate** per garantire, e poter dimostrare, che il trattamento è conforme al Regolamento.

Nel valutare l’adeguatezza, si tiene conto dei **rischi** derivanti da: distruzione, perdita, modifica, divulgazione non autorizzata o accesso in modo accidentale o illegale a dati personali.

Esempi di misure di sicurezza: - **Pseudonimizzazione** e **cifratura** dei dati personali; - Capacità di assicurare su base permanente la **riservatezza**, l’**integrità**, la **disponibilità** e la **resilienza** dei sistemi; - Capacità di **ripristinare tempestivamente** la disponibilità e l’accesso dei dati in caso di incidente fisico o tecnico; - Procedura per **testare, verificare e valutare regolarmente** l’efficacia delle misure.

L’adesione a un **codice di condotta** approvato o a un **meccanismo di certificazione** approvato può essere usata come elemento per dimostrare la conformità.

§17 — Violazione dei Dati — Data Breach (artt. 33–34 GDPR)

Notifica al Garante (art. 33)

In caso di violazione dei dati personali, il **titolare deve notificare** la violazione al **Garante privacy** senza ingiustificato ritardo e, ove possibile, entro **72 ore** dal momento in cui ne è venuto a conoscenza — **a meno che** sia improbabile che la violazione presenti un rischio per i diritti e le libertà delle persone fisiche.

(risposta alla domanda “quindi non obbligatoriamente per dati non importanti?”) Esatto. Se la violazione riguarda dati banali, già pubblici, o comunque non mette a rischio i diritti degli interessati (es. perdita di un file con dati già cifrati e non recuperabili), la notifica al Garante **non è obbligatoria**. Tuttavia il titolare deve sempre documentare internamente l'accaduto per dimostrare la propria analisi del rischio.

Se la notifica non avviene entro 72 ore, deve essere corredata dei **motivi del ritardo**.

Il **responsabile** del trattamento deve **informare il titolare** senza ingiustificato ritardo dopo essere venuto a conoscenza della violazione.

(risposta alla domanda “quindi anche più di 72 ore però?”) Sì. Il termine delle 72 ore è posto **solo** in capo al titolare nei confronti del Garante. Il responsabile deve informare il titolare “senza ingiustificato ritardo” — che è un termine più elastico e non quantificato. In pratica ci si aspetta la massima tempestività, ma la norma non fissa 72 ore per il responsabile → titolare. Questo perché il responsabile potrebbe dover svolgere accertamenti tecnici prima di comunicare, ma deve farlo senza ritardi ingiustificati.

Comunicazione all’Interessato (art. 34)

Quando la violazione **può presentare un rischio elevato** per i diritti e le libertà delle persone fisiche, il titolare deve **comunicare la violazione all’interessato** senza ingiustificato ritardo.

La comunicazione **non è richiesta** se: - il titolare ha attuato misure adeguate (es. **cifratura**) che erano applicate ai dati violati; - il titolare ha successivamente adottato misure per **scongiurare** il rischio elevato; - la comunicazione richiederebbe **sforzi sproporzionati** → si ricorre a una **comunicazione pubblica** o misura simile.

(risposta alla domanda sulla cifratura): Se i dati erano cifrati e la chiave non è stata compromessa, la violazione non crea un rischio elevato perché i dati non sono leggibili dall’attaccante — quindi la comunicazione all’interessato non è obbligatoria. Il ragionamento è corretto: “idealmente al sicuro” = non è necessaria la comunicazione. Tuttavia, se esiste un rischio **concreto e non teorico** che i dati possano essere decifrati (es. cifratura debole, chiave compromessa), il rischio elevato permane e la comunicazione diventa dovuta. La soglia è se il rischio per i diritti dell’interessato è **elevato nella realtà**, non nella teoria.

§18 — Valutazione d’Impatto sulla Protezione dei Dati — DPIA (art. 35 GDPR)

(DPIA = Data Protection Impact Assessment)

Quando è obbligatoria: quando un tipo di trattamento — in particolare con l’uso di nuove tecnologie — **può presentare un rischio elevato** per i diritti e le libertà delle persone fisiche. Il titolare deve effettuarla **prima** di procedere al trattamento.

Casi tipici in cui occorre la DPIA: - **Valutazione sistematica** e automatizzata di aspetti personali (profilazione) che fonda decisioni con **effetti giuridici** o impatto significativo sulle persone; - Trattamento su **larga scala** di categorie particolari di dati (art. 9) o di dati relativi a condanne penali; - **Sorveglianza sistematica** su larga scala di una zona accessibile al pubblico (es. telecamere a circuito chiuso in un centro commerciale).

Contenuto della DPIA: 1. **Descrizione** sistematica dei trattamenti previsti e delle finalità; 2. Valutazione della **necessità e proporzionalità** dei trattamenti rispetto alle finalità; 3. Valutazione dei **rischi** per i diritti e le libertà degli interessati; 4. **Misure** previste per affrontare i rischi (garanzie, misure di sicurezza, meccanismi di conformità).

§19 — Responsabile della Protezione dei Dati — DPO (artt. 37–39 GDPR)

Caratteristiche del DPO

- Deve essere persona **esperta** in normativa e prassi della protezione dei dati;
- Può essere **dipendente** del Titolare/Responsabile oppure **soggetto esterno** (contratto di servizi);
- **Non deve essere in conflitto di interesse** (non può avere ruoli che determinino finalità e mezzi del trattamento — es. non può essere anche responsabile IT o direttore marketing);
- **Non deve ricevere istruzioni** dal Titolare o dal Responsabile nel corso dei suoi compiti (indipendenza funzionale);
- I suoi **dati di contatto** devono essere **pubblicati e comunicati al Garante**.

Perché il DPO non deve ricevere istruzioni: il DPO è una figura di controllo e consulenza indipendente. Se ricevesse istruzioni dal Titolare, diventerebbe uno strumento del Titolare anziché un presidio di conformità. La sua indipendenza garantisce che segnali problemi reali senza pressioni interne.

Quando è obbligatoria la nomina del DPO (art. 37)

Il DPO deve essere nominato quando: 1. Il trattamento è effettuato da un'**autorità pubblica** o da un **organismo pubblico** (eccettuate le autorità giurisdizionali nell'esercizio delle loro funzioni); 2. Le **attività principali** del titolare/responsabile consistono in trattamenti che richiedono il **monitoraggio regolare e sistematico degli interessati su larga scala**; 3. Le **attività principali** consistono nel trattamento su **larga scala** di **categorie particolari di dati** (art. 9) o di dati relativi a **condanne penali e reati**.

Quando NON è obbligatorio: una PMI che tratta dati comuni dei propri clienti e dipendenti (es. una piccola agenzia pubblicitaria, un ristorante), a meno che non rientri nei casi sopra. Il GDPR non impone la nomina a tutte le organizzazioni — solo a quelle che effettuano trattamenti ad alto rischio per loro natura. La nomina volontaria è comunque sempre consentita.

Un **gruppo imprenditoriale** può nominare **un unico DPO**, purché sia facilmente raggiungibile da ciascuno stabilimento.

Compiti minimi del DPO (art. 39)

Compito	In concreto
Informare e fornire consulenza	Al titolare, al responsabile e ai dipendenti sugli obblighi derivanti dal GDPR e dalle normative privacy applicabili
Sorvegliare l'osservanza	Verifica che il titolare/responsabile rispettino il Regolamento, le normative nazionali e le policy interne

Compito	In concreto
Parere sulla DPIA	Fornisce, se richiesto, un parere sulla valutazione d'impatto e ne sorveglia lo svolgimento
Cooperare con il Garante	Punto di contatto tra l'organizzazione e l'autorità di controllo (Garante privacy)
Fungere da punto di contatto	Per le richieste degli interessati che vogliono esercitare i loro diritti

§20 — Codici di Condotta e Certificazioni (artt. 40–43 GDPR)

Codici di condotta: strumenti di autoregolamentazione settoriale, elaborati da **associazioni di categoria** o altri organismi rappresentativi di titolari/responsabili. Possono specificare come applicare il GDPR alle peculiarità di un settore (es. settore sanitario, telecomunicazioni, fintech).

In concreto: invece di dover interpretare il GDPR per ogni caso specifico, un'azienda aderisce al codice di condotta della propria associazione di categoria — che ha già fatto questo lavoro di adattamento settoriale, con il visto dell'autorità di controllo. L'adesione al codice è volontaria ma, una volta aderito, vincola al rispetto delle sue disposizioni.

Perché sono utili: (1) riducono l'incertezza interpretativa per le PMI; (2) dimostrano al Garante un impegno concreto verso la compliance; (3) possono essere usati come elemento per dimostrare l'adeguatezza delle misure di sicurezza (art. 32).

Certificazioni: meccanismi che attestano, attraverso organismi di certificazione accreditati, che il trattamento di un titolare/responsabile è conforme al GDPR.

In concreto: un'azienda si sottopone a una verifica da parte di un ente certificatore indipendente e ottiene un **sigillo o marchio di protezione dei dati**. Questo sigillo è visibile agli utenti (es. sul sito web) e agli altri titolari/responsabili con cui l'azienda collabora.

Perché sono utili: (1) aumentano la fiducia degli utenti/clienti; (2) semplificano le verifiche nelle catene di fornitura (un responsabile certificato dà garanzie aggiuntive al titolare che lo nomina); (3) possono facilitare i trasferimenti di dati extra UE come strumento di garanzia adeguata.

§21 — Trasferimenti di Dati Extra UE (artt. 44 ss. GDPR)

Principio generale: il trasferimento può avvenire solo se il titolare e il responsabile rispettano le condizioni del Regolamento, al fine di assicurare che il livello di protezione garantito dal GDPR **non sia pregiudicato**.

Come si valuta la legittimità di un trasferimento verso un paese terzo

La valutazione segue un ordine gerarchico:

Step 1 — Decisione di adeguatezza (art. 45): la Commissione Europea ha valutato che quel paese garantisce un livello di protezione **adeguato**? Se sì, il trasferimento può avvenire senza ulteriori autorizzazioni. (*Es. Giappone, Canada, Israele, Svizzera — paesi con decisione di adeguatezza.*)

Step 2 — Garanzie adeguate (art. 46): manca la decisione di adeguatezza? Il titolare/responsabile può trasferire comunque se fornisce **garanzie adeguate**, ad esempio: - **Norme vincolanti d'impresa** (*Binding Corporate Rules*): norme giuridicamente vincolanti adottate a livello di gruppo multinazionale, approvate dal Garante; - **Clausole contrattuali tipo** (*Standard Contractual Clauses*): clausole adottate dalla Commissione Europea, incluse nel contratto tra titolare e destinatario estero.

Step 3 — Deroghe (art. 49) (solo in assenza di step 1 e 2 e per trasferimenti non sistematici): - **consenso esplicito** dell'interessato, dopo essere stato informato dei possibili rischi; - **necessità per l'esecuzione di un contratto** con l'interessato; - **necessità per la conclusione/esecuzione di un contratto** nell'interesse dell'interessato; - motivi di **interesse pubblico rilevante**; - necessità per **accertare, esercitare o difendere un diritto in sede giudiziaria**; - necessità per tutelare gli **interessi vitali** dell'interessato o di altri; - trasferimento da un **registro pubblico**.

Trasferimenti UE–USA — evoluzione storica

Framework	Periodo	Fine
Safe Harbor	fino al 2015	Invalidato dalla CGUE con “Schrems I” (ottobre 2015) — accordo insufficiente perché consentiva accesso dei servizi segreti USA senza adeguate garanzie
Privacy Shield	2016–2020	Invalidato dalla CGUE con “Schrems II” (luglio 2020) — stessi problemi di sorveglianza di massa
Data Privacy Framework	dal 10 luglio 2023	Decisione di adeguatezza della Commissione UE — attualmente valido. Le aziende USA che aderiscono possono ricevere dati dall'UE

Nota: gli accordi Safe Harbor e Privacy Shield sono stati invalidati su ricorso dell'attivista austriaco Max Schrems. Il Data Privacy Framework prevede garanzie aggiuntive (tribunale speciale per i ricorsi dei cittadini europei), ma è già oggetto di possibili future sfide legali.

§22 — Sanzioni (art. 83 GDPR)

Sanzioni amministrative pecuniarie GDPR — due fasce

Fascia	Violazioni tipiche	Importo massimo
Bassa	Obblighi del titolare o responsabile (es. mancato registro, DPO non nominato, violazione obblighi art. 25)	10.000.000 EUR o 2% del fatturato mondiale dell'esercizio precedente, se superiore
Alta	Principi di base (art. 5), diritti degli interessati (artt. 15-22), liceità del trattamento (art. 6), trasferimenti extra UE	20.000.000 EUR o 4% del fatturato mondiale dell'esercizio precedente, se superiore

Esempio reale: Google è stata multata dal Garante francese (CNIL) per 50 milioni EUR (2% del fatturato) per violazione dei principi di trasparenza e delle basi giuridiche del consenso (2019).

Illeciti penali nel Codice Privacy (D.Lgs. 196/2003)

- **Trattamento illecito di dati** (art. 167);
- **Comunicazione e diffusione illecita di dati personali oggetto di trattamento su larga scala** (art. 167-*bis*);
- **Acquisizione fraudolenta di dati personali oggetto di trattamento su larga scala** (art. 167-*ter*);
- **Falsità nelle dichiarazioni al Garante e interruzione dei compiti/poteri del Garante** (art. 168);
- **Pene accessorie:** pubblicazione della sentenza sul sito del Ministero della Giustizia (art. 172).

§23 — Il Garante per la Protezione dei Dati Personali

Autorità amministrativa **indipendente**, organo collegiale composto da **quattro membri eletti dal Parlamento** (2 dalla Camera, 2 dal Senato). Mandato: **7 anni, non rinnovabile**.

Compiti principali: - Verifica l'applicazione della normativa privacy; - Esamina reclami e segnalazioni, decide sui ricorsi; - Può **vietare il trattamento illecito** e disporne il blocco; - Segnala a Governo e Parlamento l'opportunità di interventi normativi; - Esprime pareri su iniziative normative; - Denuncia fatti perseguibili d'ufficio; - Predispone una **relazione annuale**.

Riferimenti Normativi Chiave

Articolo	Contenuto	Priorità esame
GDPR art. 5	7 principi del trattamento	Alta — da sapere a memoria
GDPR art. 6	6 basi giuridiche del trattamento	Alta — da sapere a memoria

Articolo	Contenuto	Priorità esame
GDPR art. 9	Dati sensibili — divieto e deroghe A-J	Alta
GDPR artt. 12-14	Informativa — contenuto minimo	Alta
GDPR artt. 15-22	Diritti dell'interessato	Alta
GDPR art. 25	Privacy by design e by default	Alta — segnalata dalla prof
GDPR art. 30	Registri delle attività di trattamento	Media
GDPR art. 32	Misure di sicurezza	Alta
GDPR artt. 33-34	Notifica e comunicazione violazioni	Alta
GDPR art. 35	DPIA — quando e come	Alta
GDPR artt. 37-39	DPO — nomina, caratteristiche, compiti	Alta
GDPR art. 44 ss.	Trasferimenti extra UE	Media
GDPR art. 83	Sanzioni — due fasce	Alta
Codice Privacy art. 2-quinquies	Consenso minori: 14 anni in Italia	Media
Codice Privacy artt. 167-168	Illeciti penali	Media

Domande di Autoverifica — da rispondere in autonomia

(Dalla lezione — rispondere in forma discorsiva)

1. Qual è la differenza tra dato personale “comune” e dato “sensibile”? Fai tre esempi per ciascuna categoria.
2. Un'azienda vuole profilare i propri clienti per marketing. Quali basi giuridiche (art. 6) potrebbe invocare? Cosa cambia se vengono trattati anche dati relativi alla salute?
3. Descrivi la differenza tra *privacy by design* e *privacy by default* (art. 25) con un esempio concreto per ciascuno.
4. Un'azienda subisce un data breach che espone i dati di 500 clienti. Descrivi la procedura: chi fa cosa, entro quali termini, quando la comunicazione all'interessato può essere omessa.
5. Quando è obbligatorio nominare un DPO? Quali caratteristiche deve avere e quali sono i suoi compiti minimi?

Le risposte non erano presenti negli appunti grezzi. Da completare prima dell'autoverifica finale del modulo.

Collegati

- [[appunti_moduloD8]]
- [[lezione_moduloD8_privacy_gdpr]]
- [[speedreview_D08_privacy_gdpr]]

Hub: [\[\[master_map_studio\]\]](#) · [\[\[glossario_diritto\]\]](#) · [\[\[concept_maps\]\]](#)